

API.md — PrepGenie v1 API Specification

Base URL (local): `http://localhost:5000/api` **Base URL (prod):** `https://prepgenie-api.onrender.com/api`

Global conventions:

- All authenticated endpoints require header: `Authorization: Bearer <supabase_jwt>`
 - All responses use the envelope: `{ "success": boolean, "data"?: any, "error"?: string }`
 - All errors return appropriate HTTP status codes (400, 401, 403, 404, 422, 429, 500)
 - Content-Type: `application/json` unless otherwise noted (file upload uses `multipart/form-data`)
-

1. Auth Endpoints

Note: Signup/login/logout are handled client-side directly via the Supabase JS SDK (not proxied through Express), since Supabase issues and manages the JWT session. The backend only **verifies** tokens on protected routes.

1.1 `GET /api/auth/me`

Purpose: Return the authenticated user's profile (used to hydrate frontend auth context on load).

Auth: Required

Request: No body.

Response — 200:

```
json
{
  "success": true,
  "data": {
    "id": "uuid",
    "email": "user@example.com",
    "full_name": "Jane Doe",
    "target_role": "SDE Intern"
  }
}
```

Error Cases:

Status	Cause
401	Missing/invalid/expired JWT
404	User profile row not found (should auto-create on first login instead)

1.2 `PUT /api/auth/profile`

Purpose: Update user's target role / full name.

Auth: Required

Request Body:

```
json
{ "full_name": "Jane Doe", "target_role": "Data Analyst" }
```

Validation:

- `target_role` must be one of: `SDE Intern`, `Data Analyst`, `Core Engineering`, `HR Round`, `Not Set`
- `full_name` max 100 chars

Response — 200:

```
json
{ "success": true, "data": { "full_name": "Jane Doe", "target_role": "Data Anal
```

Error Cases:

Status	Cause
400	Invalid <code>target_role</code> enum value
401	Unauthenticated
422	<code>full_name</code> exceeds max length

2. Resume Endpoints

2.1 `POST /api/resume/upload`

Purpose: Upload a resume file, extract text, store file + metadata.

Auth: Required

Request: `multipart/form-data`

Field	Type	Notes
resume	file	.pdf or .docx, max 5MB

Validation:

- File type must be application/pdf or application/vnd.openxmlformats-officedocument.wordprocessingml.document
- File size ≤ 5MB
- Extracted text must be non-empty (rejects scanned/image-only PDFs)

Response — 201:

```
json
{
  "success": true,
  "data": {
    "resume_id": "uuid",
    "file_name": "jane_resume.pdf",
    "text_preview": "Jane Doe | B.Tech IT | ..."
  }
}
```

Error Cases:

Status	Cause
400	No file attached
401	Unauthenticated
413	File exceeds 5MB
415	Unsupported file type
422	Text extraction returned empty (likely scanned image PDF)
500	Storage upload failure

2.2 POST /api/resume/analyze

Purpose: Run AI analysis on a previously uploaded resume.

Auth: Required

Request Body:

json

```
{ "resume_id": "uuid", "target_role": "SDE Intern" }
```

Validation:

- `resume_id` must exist and belong to the authenticated user
- `target_role` required, must match enum

Response — 200:

json

```
{
  "success": true,
  "data": {
    "ats_score": 78,
    "missing_keywords": ["Docker", "REST API", "Unit Testing"],
    "sections": {
      "summary": { "score": 7, "suggestions": ["Add a quantifiable achievement"] },
      "skills": { "score": 8, "suggestions": ["Group skills by category"] },
      "projects": { "score": 6, "suggestions": ["Add tech stack per project"] },
      "experience": { "score": 5, "suggestions": ["Use action verbs + metrics"] }
    },
    "overall_feedback": "Solid foundation, needs more quantified impact statements"
  }
}
```

Error Cases:

Status	Cause
400	Missing <code>resume_id</code> or <code>target_role</code>
401	Unauthenticated
403	<code>resume_id</code> belongs to a different user
404	Resume not found
422	AI returned malformed JSON after retry (rare)
429	AI provider rate limit hit
500	AI service unreachable

2.3 GET /api/resume/:id

Purpose: Retrieve a specific resume's stored analysis (for re-viewing past reports).

Auth: Required

Response — 200: Same shape as 2.2's `data`, plus `file_name`, `created_at`.

Error Cases: `401`, `403` (not owner), `404` (not found)

2.4 GET /api/resume/history

Purpose: List all resumes uploaded by the user (for dashboard/history views).

Auth: Required

Query Params: `?limit=10&offset=0` (optional, defaults `limit=10`)

Response — 200:

```
json
{
  "success": true,
  "data": [
    { "resume_id": "uuid", "file_name": "resume_v2.pdf", "ats_score": 82, "crea
  ]
}
```

Error Cases: `401`

3. Interview Endpoints

3.1 POST /api/interview/start

Purpose: Start a new mock interview session; generates role-specific questions.

Auth: Required

Request Body:

```
json
{ "role": "SDE Intern", "resume_id": "uuid" }
```

Validation:

- `role` must be one of the 4 supported enums
- `resume_id` optional (if omitted, questions generate from role only, no resume personalization)

Response — 201:

```
json
{
  "success": true,
  "data": {
    "session_id": "uuid",
    "total_questions": 6,
    "current_question": { "id": "q1", "type": "technical", "question": "Explain"
  }
}
```

Error Cases:

Status	Cause
400	Invalid/missing <code>role</code>
401	Unauthenticated
403	<code>resume_id</code> provided but not owned by user
429	AI provider rate limit
500	AI generation failure after retry

3.2 `POST /api/interview/answer`

Purpose: Submit an answer for the current question; advance session state.

Auth: Required

Request Body:

```
json
{ "session_id": "uuid", "question_id": "q1", "answer_text": "REST uses fixed en
```

Validation:

- `session_id` must exist, belong to user, and have `status = 'in_progress'`
- `question_id` must exist within that session's `questions_json`
- `answer_text` non-empty, max 3000 chars

Response — 200 (more questions remain):

```
json
```

```
{
  "success": true,
  "data": { "complete": false, "next_question": { "id": "q2", "type": "behavior"
}
```

Response — 200 (last question just answered):

```
json
{ "success": true, "data": { "complete": true, "message": "All questions answer
```

Error Cases:

Status	Cause
400	Empty answer / invalid question_id
401	Unauthenticated
403	Session not owned by user
404	Session not found
409	Session already completed/abandoned

3.3 `POST /api/interview/complete`

Purpose: Finalize the session, trigger AI scoring, generate results.

Auth: Required

Request Body:

```
json
{ "session_id": "uuid" }
```

Validation: Session must belong to user and have at least 1 answered question.

Response — 200:

```
json
```

```
{
  "success": true,
  "data": {
    "overall_score": 74,
    "per_question": [
      { "question_id": "q1", "correctness": 8, "clarity": 7, "confidence": 6, "
    ],
    "weak_topics": ["System Design", "Behavioral STAR format"],
    "summary": "Strong technical fundamentals; work on structuring behavioral a
  }
}
```

Error Cases:

Status	Cause
400	No answers submitted yet
401	Unauthenticated
403	Not session owner
404	Session not found
422	AI scoring returned malformed JSON after retry
429	AI rate limit

3.4 GET /api/interview/:id

Purpose: Retrieve a completed session's full results (for history/review).

Auth: Required

Response — 200: Same shape as 3.3's `data`, plus `role`, `created_at`, `completed_at`.

Error Cases: `401`, `403`, `404`

3.5 GET /api/interview/history

Purpose: List all past interview sessions for the user.

Auth: Required

Query Params: `?limit=10&offset=0`

Response — 200:

json


```
{
  "success": true,
  "data": [
    { "session_id": "uuid", "role": "SDE Intern", "overall_score": 74, "status": "active" }
  ]
}
```

Error Cases: `401`

4. Dashboard Endpoint

4.1 `GET /api/dashboard/summary`

Purpose: Aggregate all data needed to render the dashboard in a single call (minimizes round trips).

Auth: Required

Response — 200:

```
json
{
  "success": true,
  "data": {
    "resume_score_history": [{ "date": "2026-07-28", "score": 65 }, { "date": "2026-07-27", "score": 60 }],
    "interview_averages": { "correctness": 7.2, "clarity": 6.8, "confidence": 6.5 },
    "weak_topics": ["System Design", "SQL Joins"],
    "streak_days": 4,
    "recent_activity": [
      { "type": "resume", "label": "resume_v2.pdf analyzed", "date": "2026-08-01" },
      { "type": "interview", "label": "SDE Intern mock interview", "date": "2026-08-01" }
    ]
  }
}
```

Error Cases: `401`; returns empty arrays (not an error) for new users with no activity.

5. Error Response Format (All Endpoints)

```
json
{ "success": false, "error": "Human-readable message describing what went wrong" }
```

6. Rate Limiting & Security Notes

- AI-calling endpoints (`/resume/analyze`, `/interview/start`, `/interview/complete`) are rate-limited to **10 requests per user per hour** via `express-rate-limit` keyed on `req.user.id`, to control API cost and prevent abuse.
- All `resume_id` / `session_id` ownership checks are enforced both at the Express layer (defense-in-depth) and via Postgres Row-Level Security (see SCHEMA.md §3) — a request cannot access another user's data even if a middleware check were bypassed.